
Übungsquiz Datenschutz

12 Fragen — Multiple Choice und offene Fragen mit Lösungen und ausführlicher Begründung.
Basierend auf dem Vorlesungsstoff Einheit 1–3.

Frage 1. Ziele der DSGVO

Welche Ziele verfolgt die DSGVO?

- ✓ A) Schutz natürlicher Personen
- ✓ B) Förderung des freien Datenverkehrs in der EU
- ✗ C) Harmonisierung des Steuerrechts
- ✗ D) Einschränkung des Datenverkehrs

Lösung: A, B

Begründung: Die DSGVO verfolgt zwei Hauptziele: den Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten und die Sicherstellung des freien Verkehrs personenbezogener Daten in der Union. Steuerrecht ist nicht Gegenstand der DSGVO, und der Datenverkehr soll gerade nicht eingeschränkt, sondern ermöglicht werden.

Quellen: Art 1 Abs 1 und Abs 2 DSGVO; [E1/F4]

Frage 2. Anwendbarkeit der DSGVO

Wann ist die DSGVO anwendbar?

- ✗ A) Nur bei Verarbeitung in Österreich
- ✓ B) Bei Niederlassung in der EU
- ✓ C) Bei Angebot von Waren/Dienstleistungen an Personen in der EU
- ✗ D) Nur für öffentliche Stellen

Lösung: B, C

Begründung: Die DSGVO gilt überterritorial: bei Niederlassung in der EU (Art 3 Abs 1) und beim Angebot von Waren/Dienstleistungen an Personen in der EU, auch unentgeltlich (Art 3 Abs 2 lit a). Sie beschränkt sich weder auf Österreich noch auf öffentliche Stellen.

Quellen: Art 3 Abs 1 und Abs 2 DSGVO; [E1/F10]

Frage 3. Personenbezogene Daten

Wann sind Daten personenbezogen?

- ☐ A) Wenn sie in einer Datenbank gespeichert sind
- ☒ B) Wenn eine Person identifizierbar ist
- ☐ C) Wenn eine Einwilligung vorliegt
- ☐ D) Wenn es sich um juristische Personen handelt

Lösung: B

Begründung: Personenbezogene Daten sind alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person beziehen (Art 4 Nr 1 DSGVO). Entscheidend ist die Wiedererkennbarkeit, nicht der Speicherort, das Vorliegen einer Einwilligung oder der Bezug zu juristischen Personen. Daten juristischer Personen sind grundsätzlich nicht geschützt.

Quellen: Art 4 Nr 1 DSGVO; ErwGr 30 DSGVO; [E1/F14]

Frage 4. Pseudonymisierte Daten

Welche Aussagen zu pseudonymisierten Daten sind korrekt?

- ☐ A) Pseudonymisierte Daten sind anonym
- ☒ B) Pseudonymisierte Daten bleiben personenbezogen
- ☐ C) Es gibt Erleichterungen bei pseudonymisierten Daten
- ☒ D) DSGVO gilt weiterhin

Lösung: B, D

Begründung: Pseudonymisierte Daten bleiben personenbezogene Daten, weil eine Zuordnung mit Zusatzinformationen möglich bleibt (Art 4 Nr 5 DSGVO, ErwGr 26). Die DSGVO gilt daher weiterhin vollständig. Es gibt keine generelle Ausnahme und keine allgemeinen Erleichterungen für pseudonymisierte Daten. Pseudonymisierung ist nicht gleich Anonymisierung.

Quellen: Art 4 Nr 5 DSGVO; ErwGr 26 DSGVO; [E1/F21]

Frage 5. Grundsätze nach Art 5 DSGVO

Welche Prinzipien gelten nach Art 5 DSGVO?

- ☒ A) Zweckbindung
- ☒ B) Datenminimierung
- ☐ C) Profitmaximierung
- ☒ D) Integrität und Vertraulichkeit

Lösung: A, B, D

Begründung: Art 5 Abs 1 DSGVO nennt die Grundsätze: Rechtmäßigkeit, Treu und Glauben, Transparenz, Zweckbindung, Datenminimierung, Richtigkeit, Speicherbegrenzung sowie Integrität und Vertraulichkeit. Profitmaximierung ist kein Datenschutzgrundsatz.

Quellen: Art 5 Abs 1 DSGVO; [E1/F23–F24]

Frage 6. Verantwortlicher

Wer ist Verantwortlicher im Sinne der DSGVO?

- ☒ A) Jede Person, die Daten verarbeitet
- ☒ B) Wer über Zweck und Mittel entscheidet
- ☒ C) Nur IT-Dienstleister
- ☒ D) Empfänger von Daten

Lösung: B

Begründung: Verantwortlicher ist die natürliche oder juristische Person, die allein oder gemeinsam mit anderen über Zwecke und Mittel der Verarbeitung entscheidet (Art 4 Nr 7 DSGVO). Maßgeblich ist die faktische Entscheidungskompetenz. IT-Dienstleister sind typischerweise Auftragsverarbeiter (Art 4 Nr 8), nicht Verantwortliche.

Quellen: Art 4 Nr 7 DSGVO; [E1/F17]

Frage 7. Einwilligung

Welche Aussagen zur Einwilligung sind korrekt?

- ☒ A) Muss nachweisbar sein
- ☒ B) Kann durch Schweigen erteilt werden
- ☒ C) Muss immer schriftlich erfolgen
- ☒ D) Kann jederzeit widerrufen werden

Lösung: A, D

Begründung: Einwilligung muss nachweisbar sein (Art 7 Abs 1) und ist jederzeit widerrufbar (Art 7 Abs 3). Schweigen, Untätigkeit und vorangekreuzte Checkboxes sind ausdrücklich keine gültige Einwilligung (ErwGr 32). Es gibt keine Schriftformvorschrift – die Einwilligung kann auch mündlich erteilt werden.

Quellen: Art 7 Abs 1 und Abs 3 DSGVO; ErwGr 32; [E1/F30–F32]

Frage 8. Berechtigte Interessen

Welche Aussagen zu berechtigten Interessen sind richtig?

- ☒ A) Immer anwendbar im Konzern
- ☒ B) Erfordern eine Interessenabwägung
- ☒ C) Sind klar definiert ohne Spielraum
- ☒ D) Können z. B. Direktmarketing umfassen

Lösung: B, D

Begründung: Berechtigte Interessen erfordern eine einzelfallbezogene Abwägung und sind gerade nicht klar definiert, sondern auslegungsbedürftig (Art 6 Abs 1 lit f DSGVO). Direktmarketing kann ein berechtigtes Interesse sein (ErwGr 47). Es gibt kein allgemeines Konzernprivileg; Konzernübermittlungen können nach ErwGr 48 im Einzelfall gerechtfertigt sein, aber nicht pauschal.

Quellen: Art 6 Abs 1 lit f DSGVO; ErwGr 47 und 48; [E1/F28–F29]

Frage 9. Datenschutz-Folgenabschätzung

Welche Aussagen zur Datenschutz-Folgenabschätzung (DSFA) sind korrekt?

- ☒ A) Immer durchzuführen
- ☒ B) Bei hohem Risiko erforderlich
- ☒ C) Nur für Papierakten
- ☒ D) Vorab durchzuführen

Lösung: B, D

Begründung: Eine DSFA ist erforderlich, wenn eine Verarbeitung voraussichtlich ein hohes Risiko für Rechte und Freiheiten natürlicher Personen mit sich bringt (Art 35 Abs 1 DSGVO) – nicht bei jeder Verarbeitung. Sie ist vorab, also vor Beginn der Verarbeitung, durchzuführen. Sie betrifft nicht nur Papierakten, sondern insbesondere automatisierte Verarbeitungen, Profiling und systematische Überwachung.

Quellen: Art 35 Abs 1 und Abs 3 DSGVO; [E2/F9–F13]

Frage 10. Ziele von TOMs

Welche Ziele verfolgen technische und organisatorische Maßnahmen (TOMs)?

- ☒ A) Vertraulichkeit
- ☒ B) Integrität
- ☒ C) Verfügbarkeit
- ☒ D) Abschaffung sensibler Daten

Lösung: A, B, C

Begründung: Art 32 Abs 1 DSGVO nennt als Sicherheitsziele Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste sowie die rasche Wiederherstellung des Zugangs bei Zwischenfällen. Sensible Daten werden nicht abgeschafft, sondern besonders geschützt.

Quellen: Art 32 Abs 1 lit a–d DSGVO; [E3/F7]

Frage 11. Privacy by Default

Was bedeutet „Privacy by Default“ und welche Ziele verfolgt dieses Prinzip? (4 Punkte)

Offene Frage

Musterantwort: Privacy by Default (Datenschutz durch datenschutzfreundliche Voreinstellungen) bedeutet nach Art 25 Abs 2 DSGVO, dass durch Voreinstellungen nur die für den jeweiligen Verarbeitungszweck erforderlichen personenbezogenen Daten verarbeitet werden. Das betrifft den Umfang der erhobenen Daten, den Umfang der Verarbeitung, die Speicherfrist und die Zugänglichkeit. Ziel ist, dass Datenschutz nicht erst nachträglich ergänzt wird, sondern bereits in den Grundeinstellungen eines Systems oder Produkts integriert ist. Nutzer müssen also aktiv mehr Datenfreigabe wählen, statt sich aktiv schützen zu müssen.

Quellen: Art 25 Abs 2 DSGVO; [E3/F5–F6]

Frage 12. Fallbeispiel Data Breach

Eine Mitarbeiterin versendet versehentlich eine Excel-Liste mit Bewerberdaten (inkl. teilweise sensibler Informationen) an einen falschen Empfänger. Der Fehler wird erst nach 24 Stunden entdeckt. Was ist in der Organisation zu tun? (8 Punkte)

Offene Frage

Musterantwort: **1.** Vorfall sofort intern dokumentieren: Was ist passiert, welche Daten, wie viele Betroffene, wann entdeckt? **2.** Sofortmaßnahmen einleiten: Falschen Empfänger kontaktieren und um Löschung bitten, Bestätigung der Löschung anfordern. **3.** Risikobewertung durchführen: Da Bewerberdaten mit teilweise sensiblen Informationen betroffen sind (Art 9 DSGVO), liegt ein hohes Risiko nahe. **4.** Meldung an die Datenschutzbehörde (Art 33 DSGVO) unverzüglich und möglichst binnen 72 Stunden ab Kenntnis, mit Art der Verletzung, Kategorien/ Zahl der Betroffenen, Kontaktdaten des DSB, wahrscheinlichen Folgen und ergriffenen Gegenmaßnahmen. **5.** Benachrichtigung der betroffenen Bewerber (Art 34 DSGVO), da bei sensiblen Daten ein hohes Risiko für deren Rechte und Freiheiten besteht. **6.** Lessons Learned: Awareness-Training, Überprüfung der Prozesse (z. B. Vier-Augen-Prinzip bei Massenversand), Dokumentation für künftige Nachweise.

Quellen: Art 33 und Art 34 DSGVO; [E3/F17–F21]